

Actividad 3: Análisis de Dependencias con Dependency-Check

Tema: *Detección de librerías y paquetes vulnerables*

Objetivo: *Usar Dependency-Check para analizar dependencias en un proyecto*

¿Qué es Dependency-Check?

Dependency-Check <https://owasp.org/www-project-dependency-check/> es una herramienta de código abierto de OWASP que permite identificar dependencias vulnerables en un proyecto al compararlas con bases de datos de vulnerabilidades conocidas, como **National Vulnerability Database (NVD)**. Su propósito es ayudar a los desarrolladores y equipos de seguridad a detectar y mitigar riesgos asociados con el uso de librerías desactualizadas o inseguras.

Instalar OWASP Dependency-Check

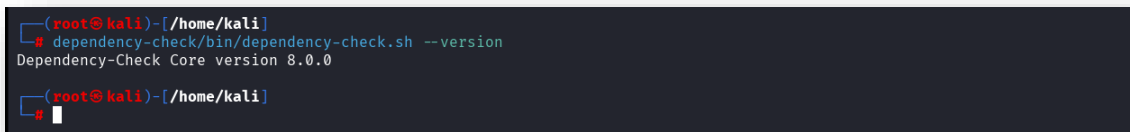
Ejecutar los siguientes comandos en la terminal:

```
wget https://github.com/jeremylong/DependencyCheck/releases/download/v12.1.0/dependency-check-12.1.0-release.zip
unzip dependency-check-12.1.0-release.zip
```

Para confirmar que la instalación fue exitosa, ejecuta:

```
dependency-check/bin/dependency-check.sh --version
```

Si la instalación es correcta, se debería mostrar la versión de la herramienta en la terminal.



Analizar un proyecto en Node.js

Para verificar vulnerabilidades en las dependencias de un proyecto basado en Node.js, crear el archivo *package-lock.json* de ejemplo con dependencias vulnerables:

```
{
  "name": "example-project",
  "version": "1.0.0",
  "lockfileVersion": 2,
  "requires": true,
```

```
"dependencies": {
  "lodash": {
    "version": "4.17.15",
    "resolved": "https://registry.npmjs.org/lodash/-/lodash-4.17.15.tgz",
    "integrity": "sha512-...==",
    "dev": false
  },
  "express": {
    "version": "4.17.1",
    "resolved": "https://registry.npmjs.org/express/-/express-4.17.1.tgz",
    "integrity": "sha512-...==",
    "dev": false
  },
  "debug": {
    "version": "2.6.9",
    "resolved": "https://registry.npmjs.org/debug/-/debug-2.6.9.tgz",
    "integrity": "sha512-...==",
    "dev": false
  }
}
```

Y ejecutar Dependency-Check:

```
dependency-check/bin/dependency-check.sh --scan package-lock.json --format HTML
```

Ejemplo de vulnerabilidad detectada:

```
High severity: lodash@4.17.15 - Prototype Pollution vulnerability
```

Después del análisis, Dependency-Check generará un informe en formato HTML con detalles sobre las vulnerabilidades encontradas.



DEPENDENCY-CHECK

Dependency-Check is an open source tool performing a best effort analysis of 3rd party dependencies; false positives and false negatives may exist in the analysis performed by the tool. Use of the tool and the reporting provided constitutes acceptance for use in an AS-IS condition, and there are NO warranties, implied or otherwise, with regard to the analysis or its use. Any use of the tool and the reporting provided is at the user's risk. In no event shall the copyright holder or OWASP be held liable for any damages whatsoever arising out of or in connection with the use of this tool, the analysis performed, or the resulting report.

[How to read the report](#) | [Suppressing false positives](#) | [Getting Help: github issues](#)

[Sponsor](#)

Project:

Scan Information ([show all](#)):

- dependency-check version: 8.0.0
- Report Generated On: Fri, 28 Feb 2025 17:59:24 -0500
- Dependencies Scanned: 2 (2 unique)
- Vulnerable Dependencies: 2
- Vulnerabilities Found: 12
- Vulnerabilities Suppressed: 0
- ...

Summary

Display: [Showing Vulnerable Dependencies \(click to show all\)](#)

Dependency	Vulnerability IDs	Package	Highest Severity	CVE Count	Confidence	Evidence Count
express:4.17.1		pkg:npm/express@4.17.1	HIGH	6		3
lodash:4.17.15		pkg:npm/lodash@4.17.15	HIGH	6		3

express:4.17.1

File Path: /home/kali/package-lock.json?express

Referenced In Project/Scope: example-project: transitive

Evidence

Identifiers

- [pkg:npm/express@4.17.1](#) (Confidence: Highest)

Published Vulnerabilities

CVE-2022-24999 (OSSINDEX) [suppress](#)

qs before 6.10.3, as used in Express before 4.17.3 and other products, allows attackers to cause a Node process hang for an Express application because an `__proto__` key can be used. In many typical Express use cases, an unauthenticated remote attacker can place the attack payload in the query string of the URL that is used to visit the application, such as `a[&__proto__]=b&a[&__proto__]&a[length]=1000000000`. The fix was backported to qs 6.9.7, 6.8.3, 6.7.3, 6.6.1, 6.5.3, 6.4.1, 6.3.3, and 6.2.4 (and therefore Express 4.17.3, which has "deps: qs@6.9.7" in its release description, is not vulnerable).

Sonatype's research suggests that this CVE's details differ from those defined at NVD. See <https://ossindex.sonatype.org/vulnerability/CVE-2022-24999> for details

CWE-1321

CVSSv2:

- Base Score: HIGH (7.5)
- Vector: /AV:N/AC:L/Au:C/Ni:N/A:H

References:

- OSSINDEX - [CVE-2022-24999] [CWE-1321](#)
- OSSIndex - <http://web.nvd.nist.gov/view/vuln/detail?vulnId=CVE-2022-24999>

Mitigación y Mejores Prácticas

* Para reducir los riesgos de seguridad en el proyecto **actualizar dependencias vulnerables** con la última versión disponible. Se pueden usar herramientas integradas como:

- **Node.js:** `npm audit fix`

```
(root@kali)-[/home/kali]
└─$ npm audit fix
npm warn tarball tarball data for express@https://registry.npmjs.org/express/-/express-4.17.1.tgz (sha512-... ==) seems to be corrupted. Trying again.
npm warn tarball tarball data for debug@https://registry.npmjs.org/debug/-/debug-2.6.9.tgz (sha512-... ==) seems to be corrupted. Trying again.
npm warn tarball tarball data for debug@https://registry.npmjs.org/debug/-/debug-2.6.9.tgz (sha512-... ==) seems to be corrupted. Trying again.
npm warn tarball tarball data for express@https://registry.npmjs.org/express/-/express-4.17.1.tgz (sha512-... ==) seems to be corrupted. Trying again.
npm warn tarball tarball data for lodash@https://registry.npmjs.org/lodash/-/lodash-4.17.15.tgz (sha512-... ==) seems to be corrupted. Trying again.
npm warn tarball tarball data for lodash@https://registry.npmjs.org/lodash/-/lodash-4.17.15.tgz (sha512-... ==) seems to be corrupted. Trying again.
npm warn cleanup Failed to remove some directories [
npm warn cleanup   [
npm warn cleanup     '/home/kali/node_modules/lodash',
npm warn cleanup     [Error: ENOTEMPTY: directory not empty, rmdir '/home/kali/node_modules/lodash/fp'] {
npm warn cleanup       errno: -39,
npm warn cleanup       code: 'ENOTEMPTY',
npm warn cleanup       syscall: 'rmdir',
npm warn cleanup       path: '/home/kali/node_modules/lodash/fp'
npm warn cleanup     }
npm warn cleanup   ],
npm warn cleanup   [
npm warn cleanup     '/home/kali/node_modules',
npm warn cleanup     [Error: ENOTEMPTY: directory not empty, rmdir '/home/kali/node_modules/lodash/fp'] {
npm warn cleanup       errno: -39,
npm warn cleanup       code: 'ENOTEMPTY',
npm warn cleanup       syscall: 'rmdir',
npm warn cleanup       path: '/home/kali/node_modules/lodash/fp'
npm warn cleanup     }
npm warn cleanup   ]
npm warn cleanup ]
```

- **Python (pip):** `pip list --outdated`

```
(root@kali)-[/home/kali]
└─$ pip list --outdated
```

Package	Version	Latest	Type
aesedb	0.1.3	0.1.6	wheel
aiocmd	0.1.2	0.1.5	wheel
aiohttp	3.10.11	3.11.13	wheel
aiomultiprocess	0.9.0	0.9.1	wheel
aiosmb	0.4.4	0.4.11	wheel
aiowinreg	0.0.7	0.0.12	wheel
alembic	1.13.2.dev0	1.14.1	wheel
antlr4-python3-runtime	4.9.2	4.13.2	wheel
anyio	4.7.0	4.8.0	wheel
apispec-webframeworks	0.5.2	1.2.0	wheel
arc4	0.3.0	0.4.0	sdist
argon2-cffi	21.1.0	23.1.0	wheel
asn1tools	0.166.0	0.167.0	sdist
asyauth	0.0.20	0.0.21	wheel
asysocks	0.2.12	0.2.13	wheel
autobahn	23.1.2	24.4.2	wheel
base58	1.0.3	2.1.1	wheel
bcrypt	4.2.0	4.3.0	wheel
bitstruct	8.19.0	8.20.0	wheel
cherry-py-cors	1.6	1.7.0	wheel
cmd2	2.5.7+ds	2.5.11	wheel
croniter	2.0.7	6.0.0	wheel
cryptography	43.0.0	44.0.1	wheel
cvss	3.2	3.4	wheel
decorator	5.1.1	5.2.1	wheel
Django	4.2.19	5.1.6	wheel
dnspython	2.6.1	2.7.0	wheel
dploit	3.0.0	3.1.2	wheel

Mantener las dependencias actualizadas es clave para prevenir ataques basados en vulnerabilidades conocidas.